CAPÍTULO 9

AUDITORÍA DE LA OFIMÁTICA

Manuel Gómez Vaz

9.1. INTRODUCCIÓN

El término ofimática, comúnmente utilizado en diferentes ámbitos profesionales, no aparece definido, sin embargo, en el diccionario de la Real Academia Española de la Lengua. Aunque el objetivo de este capítulo no consiste en determinar el concepto de ofimática ni en profundizar sobre el mismo, resulta imprescindible disponer de una definición que sirva de punto de partida para el desarrollo del tema que nos ocupa. A tales efectos, partiremos de la definición realizada por Schill, entendiendo ofimática como el sistema informatizado que genera, procesa, almacena, recupera, comunica y presenta datos relacionados con el funcionamiento de la oficina.

El concepto de ofimática nace a comienzos de la pasada década y las primeras aplicaciones se desarrollan sobre los computadores centrales de las organizaciones. Aunque las oficinas siempre han sido consideradas como pioneras en la utilización de herramientas informáticas para el desarrollo de sus actividades; desde comienzos de los noventa se ha producido un espectacular crecimiento en la demanda de sistemas ofimáticos que todavía continúa acrecentándose. Ejemplos de ello son: las aplicaciones específicas para la gestión de tareas, como hojas de cálculo o procesadores de textos; herramientas para la gestión de documentos, como control de expedientes o sistemas de almacenamiento óptico de información; agendas y bases de datos personales; sistemas de trabajo en grupo como el correo electrónico o el control de flujos de trabajos; etc.

La evolución sufrida en el entorno microinformático ha condicionado el desarrollo de los sistemas ofimáticos actuales. El aumento de la potencia de cálculo, la alta calidad de los productos y la reducción de costes de los computadores

personales y las estaciones de trabajo, ha desplazado el desarrollo de aplicaciones ofimáticas a plataformas microinformáticas y redes de área local. Hoy en día, parece incuestionable que los productos desarrollados en plataformas microinformáticas ofrecen unas prestaciones y una relación coste/beneficio muy superior a las soluciones sobre computadores centralizados. Este desarrollo de sistemas ofimáticos ha mantenido dos paradigmas fundamentales: el escritorio virtual y el trabajo cooperativo (CSCW, *Computed Supported Cooperative Work).*

Podemos aproximar el concepto de escritorio virtual como un único panel, representado por la pantalla del computador, que sustituya la mesa de trabajo tradicional, y donde se encuentren disponibles todas las herramientas necesarias para desarrollar las actividades del oficinista. La interfaz debe parecer natural al usuario y debe ser fácil de aprender y utilizar. Las diversas aplicaciones, además de realizar las tareas para las que han sido diseñadas de un modo eficaz y eficiente, deben integrarse perfectamente entre sí.

El CSCW podría considerarse como una extensión del concepto de integración de aplicaciones. De acuerdo con Kraemer, podríamos definirlo como una multiplicidad de actividades coordinadas, desarrolladas por un conjunto de participantes y soportadas por un sistema informático. Por consiguiente, el entorno ofimático, además de posibilitar la realización del trabajo personal de cada empleado, debe permitir intercambiar la información necesaria en los diversos procesos de la organización, así como posibles interacciones con otras organizaciones.

La práctica totalidad de los paquetes ofimáticos presentes en el mercado se han desarrollado siguiendo el paradigma del escritorio virtual alcanzando un grado de desarrollo aceptable incluso facilitando la integración con otros productos de diferentes fabricantes. Asimismo, durante los últimos años se ha incrementado la oferta de aplicaciones CSCW, debido principalmente al desarrollo espectacular sufrido en las comunicaciones. Este tipo de aplicaciones han incrementado sus funcionalidades y están avanzando en la implantación de estándares para la integración entre sistemas ofimáticos de distintas organizaciones.

9.2. CONTROLES DE AUDITORÍA

La mayoría de los problemas que se producen en la informatización de oficinas no difieren sustancialmente de los encontrados en otros ámbitos de la organización. Sin embargo, existen dos características peculiares de los entornos ofimáticos: la distribución de las aplicaciones por los diferentes departamentos de la organización en lugar de encontrarse en una única ubicación centralizada; y el traslado de la responsabilidad sobre ciertos controles de los sistemas de información a usuarios

finales no dedicados profesionalmente a la informática, que pueden no comprender de un modo adecuado la importancia de los mismos y la forma de realizarlos.

Como consecuencia de los dos factores enunciados, se ha generado una problemática propia en este tipo de entornos: adquisiciones poco planificadas; desarrollos ineficaces e ineficientes, incluso en procesos críticos para el correcto funcionamiento de la organización; falta de conciencia de los usuarios acerca de la seguridad de la información; utilización de copias ilegales de aplicaciones; procedimientos de copias de seguridad deficientes; escasa formación del personal; ausencia de documentación suficiente; etc.

Considerando los problemas expuestos y dejando al margen los conceptos desarrollados en el capítulo correspondiente a la auditoría de redes para evitar solapamientos, hemos elaborado una relación de controles de auditoría básicos. Los controles seleccionados, sin conformar una relación exhaustiva, han sido descritos de tal modo que puedan ser de aplicación a cualquier organización, adaptándolos a las características de la misma. En algunos entornos será necesario algún control adicional que no se encuentre entre los propuestos y en otros entornos alguno de los controles puede no resultar adecuado.

Los controles, que se presentan agrupados siguiendo criterios relacionados con aspectos de economía, eficacia y eficiencia; seguridad y condicionantes legales, son lo suficientemente generales para servir de base en la elaboración del guión de trabajo de la labor del equipo auditor.

9.2.1. Economía, eficacia y eficiencia

Determinar si el inventario ofimático refleja con exactitud los equipos y aplicaciones existentes en la organización.

A causa del bajo coste de muchos componentes, resulta difícil mantener un registro fiable de todas las compras que realiza la organización. Con frecuencia algunos departamentos sortean los procedimientos de autorizaciones de compra establecidos dentro de la organización, por ejemplo, utilizando facturas de adquisición de material no inventariable.

Un inventario poco fiable puede repercutir en el balance de la organización, posibilitando que no se detecten sustracciones de equipamiento informático o de licencias de programas contratadas. Hemos seleccionado este control en primer lugar, ya que la fiabilidad del inventario resultará indispensable para auditar otros controles presentados posteriormente.

El equipo auditor comprobará que se han definido mecanismos para garantizar que todos los equipos adquiridos en la organización son debidamente inventariados.

Después, constatará la conciliación realizada en la última auditoría financiera entre el inventario oficial y las adquisiciones efectuadas. Más tarde, revisando todas las dependencias, almacenes y archivos, elaborará una relación exhaustiva de los equipos informáticos y de las aplicaciones y archivos que residen en los mismos. En esta relación debe quedar reflejada también la versión correspondiente a cada una de las aplicaciones instaladas.

Finalmente, identificará las diferencias reales entre la relación elaborada por el equipo auditor y el inventario oficial para proceder a la subsanación de los errores detectados.

Determinar y evaluar el procedimiento de adquisiciones de equipos y aplicaciones.

Una política de adquisiciones descentralizada en la que cada departamento se encargue de realizar sus compras, ofrece ventajas en cuanto a flexibilidad y capacidad de reacción de los mismos, pero podría acarrear significativas pérdidas económicas para el conjunto de la organización.

El equipo auditor comprobará que en el procedimiento de adquisición se valoran aspectos relativos a la necesidad real de los equipos solicitados y a la integración de dichos equipos con el sistema existente. En el caso de compra de paquetes o de contratación de desarrollos externos, determinará si las prestaciones ofrecidas por el producto solicitado se ajustan a las actividades que se pretenden desarrollar con él; si las plataformas en las que van a ser instaladas las aplicaciones tienen suficiente capacidad para soportarlas de un modo eficiente; si los nuevos productos pueden configurarse, en caso de necesidad, para obtener suficientes pistas de auditoría que permitan efectuar un seguimiento de las anomalías producidas durante su ejecución; y la experiencia y solvencia del proveedor.

Partiendo, del inventario debidamente actualizado, analizará los procedimientos para la adquisición de los productos seguidos en los diversos departamentos de la organización y determinará la existencia de equipos y aplicaciones similares. En caso de que los diversos departamentos de la compañía realicen pedidos sobre equipos y complementos de manera independiente, estudiará si se está desaprovechando la posibilidad de negociar descuentos mediante la aplicación de una política centralizada de compras. Del mismo modo, considerará otros mecanismos que pudieran reducir los costes de la organización como podría ser la negociación centralizada de compra de licencias de aplicaciones.

Determinar y evaluar la política de mantenimiento definida en la organización.

Los procedimientos descentralizados han propiciado que, en ocasiones, los equipos adquiridos no sean incluidos ni en el inventario ni en los contratos de mantenimiento. Incluso podría llegar a suceder que el personal de la organización encargado del mantenimiento no dispusiera de los conocimientos necesarios para llevarlo a cabo.

El equipo auditor examinará la utilización de las garantías de los productos adquiridos, comprobando que no se realizan pagos innecesarios por asistencias de equipos y aplicaciones que se encuentren en garantía. Para ello, deberá verificar que los usuarios finales conocen el estado de las garantías de cada uno de los productos que utilizan y los mecanismos para hacerlas efectivas.

Por lo que respecta a productos cuya garantía haya caducado, determinará cuáles disponen de contratos de mantenimiento vigentes con empresas externas y cuáles son aquellos en los que la responsabilidad del mantenimiento recae en la propia organización. En las contrataciones de mantenimiento con empresas externas, verificará si se han incluido en el contrato aspectos como el tiempo máximo de respuesta, recambios y mano de obra, mantenimiento preventivo, etc. También comprobará que el personal, tanto interno como externo, asignado en tareas de mantenimiento tiene suficientes conocimientos de las plataformas que debe mantener, y que recibe la formación adecuada sobre los nuevos productos instalados en la organización.

En relación con la gestión de incidencias producidas, el equipo auditor comprobará la existencia de un registro de las mismas, los procedimientos establecidos para asignar recursos para solucionarlas, los guiones preparados para solventar las incidencias más frecuentes y el seguimiento de las mismas hasta su resolución. También valorará si el tiempo empleado para atender las solicitudes y resolver las incidencias producidas puede llegar a afectar al funcionamiento de la organización.

Evaluar la calidad de las aplicaciones del entorno ofimático desarrollada por personal de la propia organización.

La utilización de herramientas ofimáticas por los usuarios finales ha propiciado el desarrollo de aplicaciones, en muchos casos sin las debidas garantías de fiabilidad, cuyo mal funcionamiento puede repercutir significativamente en la actividad de la organización cuando se trate de aplicaciones que gestionen procesos críticos. Por otra parte, también es común que los desarrollos en estos entornos no hayan seguido los controles de calidad y seguridad suficientes, posibilitando que algún programador haya introducido "puertas traseras", bombas lógicas o cualquier otro mecanismo que pudiera perturbar el buen funcionamiento de la aplicación desarrollada.

El equipo auditor determinará la existencia de un departamento responsable de controlar el desarrollo de aplicaciones de toda la organización, y que se han definido procedimientos generales de petición, autorización, asignación de prioridades, programación y entrega de aplicaciones, o bien si los departamentos han desarrollado aplicaciones de uso interno, bajo sus propios criterios, sin control de un departamento responsable. En el caso de desarrollos realizados por personal de los propios departamentos, el equipo auditor tendrá que determinar si la metodología empleada y los test de pruebas se ajustan a lo dispuesto en la organización.

Al igual que en el caso de las aplicaciones adquiridas o desarrolladas fuera de la organización, comprobará que las aplicaciones desarrolladas internamente pueden configurarse para obtener las suficientes pistas de auditoría que permitan efectuar un seguimiento de las anomalías producidas durante su ejecución. Asimismo, verificará que los desarrollos se realizan sobre un entorno de desarrollo, evitando operar directamente sobre los datos reales de explotación.

También es tarea del equipo auditor examinar el *reporte* de incidencias de las aplicaciones, así como las reclamaciones manifestadas por los clientes y usuarios como indicios para detectar aquellas aplicaciones que podrían estar funcionando de un modo anómalo.

Evaluar la corrección del procedimiento existente para la realización de los cambios de versiones y aplicaciones.

Los cambios de aplicaciones o de versiones pueden producir situaciones de falta de integración y de incompatibilidad entre los nuevos productos instalados y los existentes con anterioridad. Prácticamente la totalidad de las nuevas versiones son capaces de manejar los formatos utilizados por versiones anteriores, pero no siempre ocurre en sentido contrario.

El equipo auditor determinará la existencia de procedimientos formalmente establecidos para la autorización, aprobación, adquisición de nuevas aplicaciones y cambios de versiones. Asimismo, comprobará que las aplicaciones instaladas y los cambios de versiones han seguido todos los trámites exigidos en el procedimiento establecido.

También se ocupará de determinar si se han analizado los problemas de integración y las incompatibilidades que pueden plantear los nuevos productos previamente a su implantación; si se ha establecido algún plan para la formación de los usuarios finales que vayan a utilizar estos nuevos productos; y si los encargados de mantenerlos han adquirido los conocimientos suficientes para que los cambios que van a producirse no impacten negativamente en el funcionamiento de la organización.

Determinar si los usuarios cuentan con suficiente formación y la documentación de apoyo necesaria para desarrollar sus tareas de un modo eficaz y eficiente.

Un conocimiento deficiente de las funcionalidades de las aplicaciones por parte de los usuarios finales o de los encargados del mantenimiento, puede ocasionar pérdida de eficacia y eficiencia en la utilización de las mismas. No debemos olvidar que carecer de los conocimientos necesarios puede ser debido tanto a que los usuarios no han sido formados como a que no han aprovechado debidamente los cursos de formación recibidos.

El equipo auditor determinará la existencia de un plan de formación para garantizar que todo el personal conoce los productos que tiene que utilizar, incluyendo las nuevas aplicaciones y las versiones instaladas. También comprobará que tras la realización de los cursos, se aplica algún mecanismo para determinar el aprovechamiento conseguido por los alumnos, y si se entrega a los usuarios documentación básica de la operativa del producto, o si pueden acceder a ella fácilmente en caso de necesidad.

Igualmente, comprobará que los empleados utilizan las posibilidades que ofrece el producto y no simulan procedimientos utilizados en versiones previas o en aplicaciones utilizadas con anterioridad. Asimismo, evaluará los mecanismos y circuitos establecidos para solucionar las dudas y problemas planteados, determinando si la responsabilidad de solucionarlos corresponde a un equipo de soporte común a toda la organización, o bien, recae sobre el propio departamento.

Determinar si el sistema existente se ajusta a las necesidades reales de la organización.

La existencia de equipos obsoletos o infrautilizados puede ocasionar situaciones que, por mala distribución de los equipos a las necesidades de la organización, repercutan en el correcto funcionamiento de la misma.

El equipo auditor valorará el uso que se realiza de los equipos existentes, elaborando una relación de aquellos computadores que no se encuentren operativos. Asimismo, revisará las actividades que se ejecutan en cada equipo, determinando aquellos puestos de trabajo que, por las tareas que desempeñan, necesitan ser automatizados o precisan actualizar los equipos existentes; así como aquellos puestos que, debido a su escasa actividad, se encuentran sobredimensionados.

A la vista de los resultados obtenidos, elaborará una relación con recomendaciones sobre descatalogación de productos obsoletos, redistribuciones y adquisiciones de nuevos equipos y aplicaciones.

9.2.2. Seguridad

Determinar si existen garantías suficientes para proteger los accesos no autorizados a la información reservada de la empresa y la integridad de la misma.

Las aplicaciones ofimáticas gestionan información reservada como agendas de contactos, informes sobre temas confidenciales, estadísticas obtenidas con información extraída de la base de datos corporativa, etc. Los accesos no autorizados o las inconsistencias en este tipo de información pueden comprometer el buen funcionamiento de la organización.

Al margen de los requerimientos que, en un futuro, disponga el reglamento de seguridad en desarrollo del artículo 9 de la Ley Orgánica 5/1992, de regulación del tratamiento automatizado de datos de carácter personal, pendiente de aprobación, la organización ha de establecer las políticas y procedimientos de seguridad necesarios para garantizar la confidencialidad, integridad y disponibilidad de la información almacenada.

Las funcionalidades en materia de seguridad de las aplicaciones ofimáticas y los sistemas operativos de los computadores personales se han incrementado significativamente en los últimos años, ofreciendo un nivel de seguridad aceptable. No obstante, garantizar el cumplimiento de algunas de las medidas de seguridad expuestas a continuación exigirá recurrir a la adquisición de paquetes adicionales y, sobre todo, la adopción de medidas organizativas.

El equipo auditor examinará la documentación en materia de seguridad existente en la organización y comprobará que han sido definidos, al menos, procedimientos de clasificación de la información, control de acceso, identificación y autenticación, gestión de soportes, gestión de incidencias y controles de auditoría. Con posterioridad, pasará a comprobar si las medidas de seguridad definidas se encuentran realmente operativas.

En primer lugar, determinará si el procedimiento de clasificación de la información establecido ha sido elaborado atendiendo a la sensibilidad e importancia de la misma, y comprobará que toda la información se ha clasificado en función de los criterios establecidos.

Tras verificar que las funciones, obligaciones y responsabilidades, en materia de seguridad, de cada puesto de trabajo están claramente definidas y documentadas, comprobará que se han adoptado las medidas necesarias para que todo el personal conozca tanto aquellas que afecten al desempeño de su actividad como las responsabilidades en que pudiera incurrir en caso de incumplirlas.

Examinando la relación actualizada de usuarios del sistema y de derechos de acceso establecidos, comprobará que cada usuario tiene autorización para acceder únicamente a aquellos datos y recursos informáticos que precisa para el desarrollo de sus funciones.

El equipo auditor deberá comprobar si se han establecido procedimientos de identificación y autenticación para el acceso al sistema. Cuando el mecanismo de autenticación se base en contraseñas, determinará si el procedimiento de creación, almacenamiento, distribución y modificación de las mismas garantiza su confidencialidad. También, determinará si los usuarios desconectan sus puestos de trabajo al finalizar la jornada, y si existe algún mecanismo que produzca la desconexión automática de un usuario tras un período de inactividad determinado, o bien, que precise introducir una contraseña para poder reanudar el trabajo.

En ningún caso olvidará verificar el cumplimiento de los procedimientos establecidos para solicitar nuevos accesos o modificaciones sobre los derechos definidos para un usuario, y que, exclusivamente, el personal autorizado se ocupará de conceder, alterar o anular los derechos de acceso sobre los datos y recursos informáticos.

El equipo auditor analizará el procedimiento de notificación y gestión de incidencias definido en la autorización, determinando cuáles son las incidencias registradas, el momento en que se producen, la persona que realiza la notificación, a quién le son comunicadas, el responsable asignado para revisarla y corregirla, los efectos producidos y las actuaciones que ha provocado.

Finalmente, comprobará que todos los soportes informáticos permiten identificar la información que contienen, son inventariados y se almacenan en un lugar con acceso restringido únicamente al personal autorizado. Igualmente, verificará que la salida de soportes informáticos fuera de la organización es debidamente autorizada.

Determinar si el procedimiento de generación de las copias de respaldo es fiable y garantiza la recuperación de la información en caso de necesidad.

La información generada por el sistema debe estar disponible en todo momento. La no disponibilidad de datos, especialmente de aquellos procedimientos críticos para la organización, además de las consabidas pérdidas económicas, podría llevar, en el extremo, a la paralización del departamento.

El equipo auditor examinará el procedimiento de copias de seguridad seguido en la organización, verificando la suficiencia de la periodicidad, la correcta asignación de responsabilidades y el adecuado almacenamiento de los soportes.

En primer lugar, comprobará que la responsabilidad de realizar las copias de seguridad está asignada y que cada responsable realiza copias de la información que se encuentra bajo su responsabilidad, de tal forma que todos los datos son salvaguardados. A continuación, verificará la existencia de un inventario de los soportes que contienen las copias de seguridad y de la información salvaguardada.

Posteriormente, determinará si la seguridad implementada para garantizar la confidencialidad e integridad de las copias de salvaguarda ofrece garantías equivalentes a las definidas para la información que contienen, tanto en los soportes que se mantienen en los locales de la empresa como en aquellos que se trasladan a una ubicación externa.

Finalmente, controlará la eficacia del procedimiento definido para la recuperación de las copias de seguridad, determinando si los soportes contienen la información que está previsto que contengan, y si es posible la recuperación de la misma, de forma que el resultado final sea un fiel reflejo de la situación anterior.

Determinar si está garantizado el funcionamiento ininterrumpido de aquellas aplicaciones cuya caída podría suponer pérdidas de integridad de la información y aplicaciones.

En las organizaciones se desarrollan procesos en los que una caída de tensión podría ocasionar pérdidas de integridad de la información y aplicaciones manejadas, en ocasiones irrecuperables.

El equipo auditor determinará la existencia de sistemas de alimentación ininterrumpida, y si éstos cubren el funcionamiento de aquellos equipos en los que se ejecutan procesos cuya interrupción podría ocasionar graves repercusiones.

Asimismo, debe ocuparse de similar una caída de tensión, verificar si los equipos de alimentación ininterrumpida entran en funcionamiento y comprobar si el tiempo de actividad proporcionado por el sistema de alimentación ininterrumpida es suficiente, para la finalización de los procesos críticos y la desconexión del sistema.

Determinar el grado de exposición ante la posibilidad de intrusión de virus.

Los costes derivados de la intrusión de virus informáticos se han multiplicado en los últimos años: pérdida de la información y empleo de recursos y tiempo para restablecer el sistema, llegando en algunos casos a la paralización temporal del departamento.

El equipo auditor analizará la protección establecida en cada uno de los puntos del sistema por los que podrían introducirse virus: disqueteras, módem, accesos a

redes, etc.; y revisará la normativa para la instalación y actualización periódica de productos antivirus, prestando especial atención a aquellos casos en que la información manejada puede ser crítica para el funcionamiento de la organización.

Asimismo, analizará la configuración de los equipos y la instalación de programas que permitan detectar la existencia de virus, evitar su intrusión en el sistema y eliminar aquellos que se hayan introducido.

En caso de que detectara algún virus en alguno de los equipos, el equipo auditor informará inmediatamente al responsable autorizado sugiriendo las medidas que estime pertinentes para evitar la propagación del mismo.

9.2.3. Normativa vigente

Determinar si en el entorno ofimático se producen situaciones que puedan suponer infracciones a lo dispuesto en la Ley Orgánica 51/1999, de protección de datos de carácter personal (LOPD).

La LOPD establece una serie de principios y derechos de los ciudadanos en relación con sus datos de carácter personal incluidos en archivos automatizados.

Además, aquellos afectados que sufran daño o lesión en sus bienes o derechos como consecuencia del incumplimiento de lo dispuesto en la LOPD, pueden reclamar la correspondiente indemnización ante los Tribunales de Justicia.

El equipo auditor deberá comprobar la existencia de un inventario de archivos que manejan datos de carácter personal y constatar que este inventario contiene todos los archivos gestionados en los entornos ofimáticos. Aunque en la mayoría de los casos estos entornos gestionan archivos que se constituyen como meramente auxiliares de otros existentes en la organización, en algún supuesto podrían tratarse datos personales que no se encontraran incluidos en ninguno de los archivos o bases de datos corporativas. La tarea del equipo auditor consistirá en determinar que los archivos que gestionan datos personales en entornos ofimáticos se encuentran bajo control y que han sido notificados al Registro General de la Agencia de Protección de Datos.

Los controles para verificar que los archivos existentes cumplen los preceptos establecidos en la LOPD no pueden excluirse de los procedimientos generales para toda la organización, excediendo, por consiguiente, del alcance del presente capítulo.

Baste recordar que el equipo auditor deberá comprobar la adecuación y validez de los procedimientos establecidos en la organización para garantizar el cumplimiento de los principios (calidad de los datos, información en la recogida, consentimiento del afectado para el tratamiento y la cesión, seguridad de datos, deber de secreto, etc.) y derechos (acceso, rectificación y cancelación) recogidos en la mencionada Ley.

Determinar si en el entorno ofimático se producen situaciones que puedan suponer infracciones a lo dispuesto en el Real Decreto Legislativo 1/1996, de 12 de abril, sobre la propiedad intelectual.

La mayoría de las copias ilegales utilizadas en las organizaciones corresponden a aplicaciones microinformáticas, en especial a aplicaciones ofimáticas. Este hecho puede provocar que aquellos afectados que sufran algún tipo de daño o perjuicio como consecuencia del incumplimiento de lo dispuesto en el Real Decreto Legislativo sobre la propiedad intelectual, presenten reclamaciones ante los Tribunales de Justicia que puedan derivar incluso causas criminales.

El equipo auditor deberá elaborar una relación exhaustiva de las aplicaciones, residentes en equipos ofimáticos, que precisen licencia para su utilización. Esta relación se contrastará con el inventario de la organización para verificar que coinciden, y, en caso contrario, deberá averiguar cuáles son las copias ilegalmente utilizadas.

El equipo auditor se ocupará de verificar la definición y aplicación de medidas con carácter preventivo, tales como: la existencia de un régimen disciplinario que sea conocido por todos los empleados, la inhabilitación de las disqueteras y otros puertos de entrada y salida, y las limitaciones en el acceso a redes externas a la organización.

Igualmente, verificará las medidas detectivas existentes tales como: la asignación de responsables que se ocupen de efectuar exploraciones periódicas de las aplicaciones contenidas en cada computador y de analizar los niveles de utilización de las aplicaciones compartidas en la red.

Finalmente, comprobará la definición de medidas correctivas tales como: la eliminación de las copias ilegales que se localicen; los procedimientos para determinar el modo de intrusión y, en consecuencia, definir medidas para evitar que esta situación se repita; y adoptar las acciones disciplinarias pertinentes.

9.3. CONCLUSIONES

La mayoría de las aplicaciones de auditoría en entornos ofimáticos no difiere sustancialmente de las actuaciones necesarias para auditar sistemas centralizados. En ambos casos, la experiencia profesional del auditor supone el elemento fundamental

para la selección de los controles objeto de verificación y la adecuación de los mismos al sistema a auditar, teniendo presente en todo momento que la evolución sufrida por los entornos ofimáticos exigirá conocimientos específicos y técnicas novedosas.

La presentación de los controles muestra una secuencia en las actuaciones a realizar en la auditoría. Como paso previo al inicio de la auditoría propiamente dicha, el equipo auditor debe comprender en profundidad el funcionamiento del sistema y del uso que se hace del mismo, así como analizar los riesgos a los que está expuesto. Para cada uno de los aspectos a revisar, debe comprobar la definición de controles preventivos, detectivos y correctivos. Acto seguido, debe verificar si los controles definidos son realmente aplicados por los usuarios durante el desarrollo de sus actividades. Finalmente, deberá emitir una valoración acerca de la suficiencia y adecuación de los controles definidos e implantados para la prevención de los riesgos a los que se encuentra sometido el sistema.

Durante la exposición de los controles, nos hemos referido con frecuencia a documentos, procedimientos y políticas de actuación definidas e implantadas en la organización; sin embargo, es un hecho habitual que algunos de ellos no hayan sido definidos. Es labor del auditor, además de constatar tales deficiencias en su informe, participar en la elaboración de los mismos. Es decir, el auditor debe ocuparse de detectar las deficiencias presentes en el funcionamiento de la organización, pero, además, debe contribuir con su experiencia y conocimientos en la elaboración de los procedimientos y recomendaciones que permitan subsanarlas.

Como consideración final, recomendar que la auditoría ofimática no debe realizarse de un modo independiente. Nos parece más adecuada la integración de los controles ofimáticos dentro de un plan de auditoría de mayor alcance, principalmente por motivos de eficacia y eficiencia en la preparación y desarrollo de la misma.

9.4. LECTURAS RECOMENDADAS

Thomas, A. J., Douglas, I. J. *Auditoría informática.* Paraninfo, 1987.

Ron Weber *EDP auditing. Conceptual foundations and practice.* McGraw Hill, 1988.

Kraemer, K. L., King, J. L. *Computer-Based systems for Cooperative Work and Group Decisions Making.* ACM Comp. Surveys, vol. 20, n.º 2, junio 1988, pp. 115-146.

Auerbach Publicactions. *EDP Auditing,* 1993. Capítulos 74-01-01, 74-01-05, 74-0174-01-30, 74-01-65, 74-01-71 y 75-01-15.

Schill, Alexander. *Cooperative office systems: Concepts.* Prentice Hall, 1995.

9.5. CUESTIONES DE REPASO

1. ¿Qué elementos de un sistema informático se contemplan dentro de la ofimática?

2. Explique el paradigma de escritorio virtual.

3. ¿Qué distingue la auditoría de ofimática de la de otros entornos informáticos?

4. Analice las repercusiones que puede tener en una empresa un inventario poco fiable bajo las perspectivas de la economía, la eficacia y la eficiencia.

5. ¿Cómo debería ser un procedimiento para la realización de cambios de versiones de paquetes ofimáticos?

6. Calcule el coste real de un computador personal para una empresa (tenga en cuenta el hardware, software, mantenimiento, formación, etc.).

7. ¿Qué mecanismos de seguridad de los que conoce se pueden aplicar a los computadores personales?

8. Escriba un procedimiento para la utilización de equipos ofimáticos que pueda ser entendido por usuarios finales.

9. Analice las principales "vacunas" existentes en el mercado contra virus que afecten a computadores personales.

10. ¿Qué consideraciones al entorno ofimático se encuentran en la LOPD?